

PROPOSAL TEKNIS

IPB SPACE

Sistem Informasi Aman dengan Implementasi Kriptografi & Protokol AAA

Mata Kuliah Keamanan Informasi (KOM1315)
Semester Genap 2026

Disusun oleh (Kelompok 11):

Daffa Aulia Musyaffa Subyantoro	G6401231028
Hakim Ilyas Azhar	G6401231077
Kivi Adelio	G6401231047

DEPARTEMEN ILMU KOMPUTER FAKULTAS MATEMATIKA DAN ILMU PENGETAHUAN
ALAM
IPB UNIVERSITY
2026

Daftar Isi

Deskripsi Sistem	3
Latar Belakang	3
Gambaran Sistem	3
Tujuan Sistem	3
Arsitektur Sistem	4
Fitur Inti	4
Katalog Fasilitas & Kalender	4
Alur Pemesanan Cerdas	5
Manajemen Konflik Jadwal	5
Tiket Digital & QR Code Validator	5
Audit Logging	5
Identifikasi Aset	6
Aset Data	6
Aset Layanan (API Endpoint)	6
Aset Infrastruktur	7
Model Kepercayaan dan Batas Akses	7
Zona Kepercayaan	7
Matriks Peran dan Akses	8
Stack dan Dependensi Kunci	9
Dependensi Backend (FastAPI)	9
Dependensi Frontend (Next.js)	9
Mekanisme Keamanan Utama	10
Hashing Kredensial (Bcrypt)	10
Otentikasi & Otorisasi Sesi (JWT & HttpOnly Cookie)	10
Integritas & Non-Repudiasi Tiket (RSA-SHA256 Digital Signature)	10

Deskripsi Sistem

Latar Belakang

IPB University memiliki berbagai fasilitas publik berupa ruang kuliah, laboratorium, auditorium, dan ruang rapat yang tersebar di berbagai fakultas maupun unit kerja pusat. Hingga saat ini, proses peminjaman ruangan dan fasilitas tersebut sering kali dihadapkan pada beberapa kendala operasional, seperti terjadinya konflik jadwal pemesanan ganda (**overlapping booking**), prosedur permohonan yang kurang transparan, tumpukan berkas pendukung fisik, serta tidak adanya **audit log** yang aman untuk melacak aktivitas transaksi pemesanan secara andal.

Selain kendala operasional, aspek keamanan data juga menjadi tantangan krusial. Sistem informasi peminjaman fasilitas yang ada belum mengimplementasikan mekanisme perlindungan data yang kuat sesuai standar Keamanan Informasi. Transmisi kredensial pengguna, berkas pendukung yang diunggah civitas, serta tiket pemesanan yang diterbitkan rawan terhadap ancaman manipulasi (**tampering**), pencurian sesi (**session hijacking**), dan penyangkalan transaksi (**repudiation**).

Sebagai solusi inovatif, **IPB Space** dikembangkan sebagai sistem informasi pemesanan fasilitas kampus berbasis web yang aman dengan mengintegrasikan kontrol akses ketat melalui protokol **Authentication, Authorization, dan Accounting** (AAA) serta jaminan integritas data transaksi menggunakan teknik kriptografi asimetris (**Digital Signature**).

Gambaran Sistem

IPB Space menyediakan layanan pemesanan fasilitas secara terpusat untuk civitas akademika IPB (mahasiswa, dosen, dan tenaga kependidikan). Sistem ini memadukan beberapa komponen utama:

1. **Katalog & Kalender Interaktif:** Memungkinkan seluruh pengguna untuk melihat detail ruangan, aset yang tersedia, dan jadwal pemakaian secara **real-time**.
2. **Alur Pemesanan dengan Proteksi Dokumen:** Civitas dapat mengajukan pemesanan dengan menentukan waktu, memilih barang tambahan (**extra items**), dan mengunggah dokumen pendukung secara digital.
3. **Mesin Validasi Konflik Jadwal:** Backend secara otomatis memeriksa tumpang tindih waktu untuk mencegah pemesanan ganda sebelum permohonan diteruskan ke Admin Fasilitas.
4. **Tiket Digital dengan QR Code Terenkripsi:** Tiket pemesanan yang disetujui dibekali payload QR Code yang ditandatangani menggunakan tanda tangan digital berbasis kunci privat RSA backend.
5. **Audit Logging Komprehensif:** Setiap peristiwa kritis (registrasi, login, approval, edit data master) dicatat dalam format terstruktur yang aman.

Tujuan Sistem

Menyediakan media pemesanan fasilitas kampus yang transparan, mudah, dan bebas dari konflik jadwal pemakaian. Melindungi integritas data pemesanan dan berkas civitas dari akses tidak sah. **Menjamin keaslian (authenticity) tiket digital pemesanan sehingga terhindar dari pemalsuan tiket oleh pihak luar.** Menerapkan prinsip **non-repudiation** (anti-penyangkalan) bagi Admin Fasilitas yang menyetujui pemesanan menggunakan tanda tangan digital. **Memfasilitasi audit keamanan sistem secara berkala dengan log terstruktur yang andal.**

Arsitektur Sistem

Sistem IPB Space dirancang menggunakan arsitektur **client-server** tiga lapisan (**three-tier**) dengan pemisahan peran yang tegas:

Lapisan	Teknologi		Keterangan
Frontend	Next.js 15,	React 19,	Antarmuka civitas, admin, dan super admin. Mengelola state sesi melalui HttpOnly cookies.
Backend	FastAPI	(Python 3.10), Uvicorn	Penyedia REST API utama, menangani logika bisnis, validasi konflik, otorisasi peran, dan audit logging.
Database	PostgreSQL		Penyimpanan data persisten pengguna, data ruang, booking, aset, ekstra barang, dan log audit.
Autentikasi	JWT (JSON Web Token), Bcrypt		Protokol AAA: hashing password civitas dengan Bcrypt, transfer token JWT sebagai otorisasi peran.
Kriptografi	RSA-SHA256 Cryptography)	(Module	Pembuatan kunci asimetris untuk menandatangani data tiket pemesanan yang disetujui.
Notifikasi	Resend API, Jinja2		Pengiriman email notifikasi status pemesanan secara asinkron ke civitas.
Logging	Structlog logging)	(Structured	Logging aktivitas terstruktur yang dialirkan ke file eksternal.

Fitur Inti

Katalog Fasilitas & Kalender

Menampilkan seluruh fasilitas kampus (misal: Aula GWW, Lab Komputer A, Ruang Rapat Senat) beserta status kelayakan, kontak narahubung, dan kalender ketersediaan dinamis.

Alur Pemesanan Cerdas

Civitas mengisi formulir pemesanan, menentukan perkiraan jumlah peserta, mengunggah file PDF dokumen pendukung, dan meminta barang pendukung tambahan (misalnya standing banner, kursi lipat, modem wifi portable).

Manajemen Konflik Jadwal

Ketika transaksi diajukan, backend FastAPI menjalankan query pencarian irisan waktu secara otomatis:

$$S < E_{\text{existing}} \text{ dan } E > S_{\text{existing}}$$

Di mana S dan E adalah waktu mulai (**start**) dan selesai (**end**) pemesanan baru. Jika ditemukan irisan pada hari yang sama untuk ruangan yang sama, pengajuan langsung dicegah secara otomatis.

Tiket Digital & QR Code Validator

Tiket yang disetujui akan diencode menjadi payload JSON berisi data identitas pemesanan, id ruangan, dan nama civitas. Payload tersebut ditandatangani secara kriptografis menggunakan kunci privat RSA server backend, menghasilkan **Digital Signature**. QR Code diterbitkan dari gabungan payload dan signature ini. Di lapangan, petugas fasilitas memindai QR Code tersebut dan backend akan memvalidasi keaslian tanda tangan menggunakan kunci publik RSA server.

Audit Logging

Setiap aksi perubahan status pemesanan, penghapusan fasilitas, perubahan stok barang ekstra, dan aktivitas login mencatat identitas pelaku (**user ID**), waktu (**timestamp**), alamat IP (**IP Address**), dan jenis aktivitas (**event category**).

Identifikasi Aset

Identifikasi aset dilakukan untuk memetakan seluruh data, layanan, dan komponen infrastruktur dalam sistem IPB Space, serta mengklasifikasikan tingkat sensitivitas dan risiko keamanan masing-masing aset.

Aset Data

Aset data dinilai berdasarkan dampaknya terhadap privasi civitas akademika dan kredibilitas institusi jika terjadi kebocoran atau manipulasi data.

Entitas Data	Tabel DB	Atribut Sensitif	Nilai
Kredensial Pengguna	users, superadmins, civitas, managers	password (hashed bcrypt), email, idnum (NIM/NIP), token JWT aktif	Kritis
Berkas Pemesanan	bookings	document_url, purpose, attendees_count, validated_by	Tinggi
Tiket & Validasi	bookings	digital_signature, check_in_time	Tinggi
Master Fasilitas	facilities, assets	name, code, contact_person, capacity, condition	Sedang
Inventaris Barang	items, extra_items	name, category, total_stock, storeroom_location	Sedang

Aset Layanan (API Endpoint)

Endpoint layanan diklasifikasikan berdasarkan peran yang diperbolehkan mengaksesnya untuk menghindari kerentanan **Broken Object Level Authorization** (BOLA) dan **Broken Function Level Authorization** (BFLA).

Endpoint API	Metode	Fungsi Layanan
/api/v1/auth/login	POST	Otentikasi pengguna, menerbitkan JWT, mencatat login log.
/api/v1/auth/logout	POST	Invalidering token JWT, menghapus sesi di database.
/api/v1/bookings	POST	Pengajuan booking baru oleh Civitas (disertai unggahan file).

/api/v1/bookings/conflict	GET	Pemeriksaan real-time ketersediaan slot pemesanan.
/api/v1/bookings/{id}/approve	POST	Validasi pemesanan ruangan dan penandatanganan digital tiket oleh Manager Fasilitas.
/api/v1/bookings/{id}/verify-ticket	POST	Verifikasi tanda tangan digital QR Code tiket saat check-in fisik.
/api/v1/admin/users	GET/ POST	CRUD Pengguna & otorisasi peran (Super Admin saja).
/api/v1/admin/facilities	POST/ PUT	CRUD Data master ruangan oleh Super Admin/Manager Fasilitas.

Aset Infrastruktur

Aset fisik dan server runtime yang mendukung ketersediaan operasional sistem IPB Space.

Komponen	Deskripsi	Nilai
Server FastAPI	Runtime ASGI (Uvicorn) pengeksekusi kode logika bisnis backend.	Kritis
Server Next.js	Runtime Node.js untuk rendering antarmuka pengguna frontend.	Tinggi
Database PostgreSQL	Penyimpanan data relasional transaksi pemesanan dan log audit.	Kritis
JWT Secret Key	Kunci rahasia untuk menandatangani token akses JWT.	Kritis
Kunci Privat RSA	Kunci privat asimetris backend untuk menandatangani QR Code tiket.	Kritis
Kunci Publik RSA	Kunci publik asimetris untuk memverifikasi QR Code tiket.	Tinggi

Model Kepercayaan dan Batas Akses

Zona Kepercayaan

Sistem IPB Space mendefinisikan tiga zona kepercayaan:

1. **Zona Publik:** Pengguna luar/tamu yang belum terautentikasi. Hanya dapat mengakses katalog publik dan melakukan request login.

2. **Zona Terautentikasi (JWT):** Pengguna terautentikasi (Civitas, Manager Fasilitas, Super Admin). Akses dibatasi menggunakan skema **Role-Based Access Control (RBAC)** pada API route backend.
3. **Zona Internal:** Area komunikasi eksklusif antara backend FastAPI dan database PostgreSQL melalui koneksi TCP yang aman dan terisolasi.

Matriks Peran dan Akses

Berikut merupakan pembagian hak akses fitur bagi masing-masing peran dalam sistem IPB Space:

Fitur Sistem	Tamu	Civitas	Manager Fas.	Super Admin
Melihat Katalog & Jadwal	✓	✓	✓	✓
Mengajukan Pemesanan	-	✓	-	-
Melacak Status & Tiket QR	-	✓	-	-
Menyetujui & Menolak Booking	-	-	✓	-
Menandatangani Tiket (RSA)	-	-	✓	-
Memindai & Validasi Check-In	-	-	✓	-
Manajemen Pengguna (CRUD)	-	-	-	✓
Manajemen Ruangan & Barang	-	-	✓ (Terbatas)	✓
Melihat Log Audit Sistem	-	-	-	✓

Stack dan Dependensi Kunci

Dependensi Backend (FastAPI)

Untuk menjamin keamanan penulisan kode, validasi input, serta implementasi kriptografi, backend FastAPI menggunakan paket-paket utama berikut:

Paket Backend	Versi	Peran / Fungsi Keamanan
fastapi	0.128.0	Framework REST API utama, mendukung dependency injection untuk otorisasi.
sqlalchemy	2.0.46	ORM relasional aman, mencegah serangan SQL Injection secara bawaan.
alembic	1.18.3	Manajemen migrasi skema database relasional secara terversi.
pydantic	2.12.5	Validasi input data terikat (strict type validation) dan sanitasi data request.
bcrypt	5.0.0	Hashing password satu arah menggunakan algoritma Blowfish Crypt untuk storage user.
PyJWT	2.10.1	Penerbitan dan pemetaan token JWT untuk pertukaran data otorisasi yang aman.
cryptography	46.0.4	Implementasi algoritma RSA asimetris untuk digital signature tiket pemesanan.
structlog	Lest	Logging terstruktur berkinerja tinggi untuk kebutuhan log audit sistem.

Dependensi Frontend (Next.js)

Frontend Next.js dirancang untuk menyajikan data secara dinamis serta mengelola interaksi pengguna dengan mengutamakan aspek keamanan sisi klien.

Paket Frontend	Versi	Peran / Fungsi Keamanan
next	15.5.2	Framework React full-stack dengan Server-Side Rendering (SSR) untuk proteksi route.
react	19.1.0	Perpustakaan UI komponen utama.

tailwindcss	^4.0.0	Utility-first CSS untuk visualisasi antarmuka premium.
-------------	--------	--

Mekanisme Keamanan Utama

Hashing Kredensial (Bcrypt)

Untuk mencegah kebocoran password civitas apabila database terekspos, password disimpan dalam format hash menggunakan algoritma Bcrypt dengan penambahan **salt** acak secara dinamis.

$$H = \text{Bcrypt}(P_{\text{raw}}, \text{salt})$$

Otentikasi & Otorisasi Sesi (JWT & HttpOnly Cookie)

Token JWT ditandatangani menggunakan algoritma simetris HS256 dengan kunci JWT_SECRET yang kuat. Untuk mencegah serangan **Cross-Site Scripting (XSS)**, token ini tidak disimpan dalam LocalStorage sisi klien, melainkan dikirim ke browser menggunakan header Set-Cookie dengan flag HttpOnly, Secure, dan SameSite=Strict.

Integritas & Non-Repudiasi Tiket (RSA-SHA256 Digital Signature)

Ketika pemesanan disetujui, data tiket diformat dalam string JSON terurut:

$$T = \{\text{id} : \text{B-001}, \text{room} : \text{RK-U1-01}, \text{user} : \text{civitas}\backslash\text{@ipbspace.com}, \text{date} : \text{2026-06-03}\}$$

Backend memproses string tersebut dengan fungsi hash SHA-256, kemudian mengenkripsinya menggunakan Kunci Privat RSA milik server backend untuk menghasilkan Tanda Tangan Digital:

$$S = E_{K_{\text{private}}}(\text{SHA-256}(T))$$

Tanda tangan S ini disimpan dalam database di kolom `digital_signature` dan disertakan dalam QR Code tiket. Saat dilakukan pemindaian check-in, sistem akan mendekripsi S menggunakan Kunci Publik RSA server:

$$D = D_{K_{\text{public}}}(S)$$

Jika hasil dekripsi D cocok dengan nilai $\#$ SHA-256 dari data tiket aktual, maka tiket dinyatakan SAH dan tidak mengalami manipulasi (**integrity guaranteed**), serta dipastikan diterbitkan oleh Manager Fasilitas yang sah (**non-repudiation guaranteed**).